広域スキャンで検知される脆弱性とランサムウェア被害の関連性の分析

三井 亜依[1,a)]　海藤 十和[2]　インミンパパ[3]　吉岡 克成[4]

概要：
近年，ランサムウェア攻撃は世界的に増加しており，企業・教育機関・医療機関など多様な組織が被害を受けている．侵入経路は多岐にわたるが，インターネットに公開された VPN 機器や Web アプリケーション等における既知脆弱性の悪用は現在も主要な経路の一つであり，これを起点とする攻撃は身代金要求額が高額化する傾向にある．組織の脆弱性や攻撃者の挙動については多くの研究が行われている．しかし，ランサムウェア被害組織のインターネットから到達可能な資産に，被害前からどのような脆弱性が観測されていたのか，また，その特徴が同様の属性を持つ非被害組織と異なるのかについては，十分に明らかになっていない．そこで本研究では，実際にランサムウェア攻撃の被害を受けたとされる組織を対象に，攻撃発生時点と考えられる時点の公開資産における脆弱性を調査し，属性を揃えた統制群との症例対照比較を通じて，観測された傾向が被害組織に特有のものかを検証する．具体的には ransomware.live 由来の被害組織データと統制群を対象に，Censys・DNSDB・Shodan による攻撃時点の公開資産・脆弱性情報の再構成に，NVD・CISA KEV・FIRST EPSS を統合した分析パイプラインを両群に適用する．これにより，第一に，脆弱性検出率・CVSS 深刻度・EPSS スコア・KEV 収載状況等の複数指標について系統的な差が見られるかを検証する．第二に，差が観測された指標については，その差が特定の脆弱性や母集団の一部に依存する見かけ上のものでないかを，母集団定義・対照比率を変えた頑健性検証により確認する．分析の結果，脆弱性検出率・CVSS・EPSS については系統的な差は見られなかった．ランサムウェア悪用既知の脆弱性の保有率についてのみ境界的な有意差が観測されたが，この差は単一の既知脆弱性に起因し，頑健性検証によってもこの構造は変わらなかった．すなわち本研究の結果は，今回のデータでは外部から観測可能な脆弱性指標に一貫した差を確認できなかったことを示すものであり，CVE/CVSS ベースの指標のみでの判別には限界があることを示唆する．

キーワード：ランサムウェア, 症例対照研究, 攻撃対象領域, KEV/EPSS

Analyzing the Relationship Between Internet-Wide Scan-Detected Vulnerabilities and Ransomware Victimization

Ai Mitsui[1,a)]　Towa Kaidou[2]　Yin Minn Pa Pa[3]　Katsunari Yoshioka[4]

Abstract: Ransomware attacks have been increasing worldwide, and the exploitation of known vulnerabilities in Internet-facing devices such as VPN appliances remains a leading intrusion vector, often associated with higher ransom demands. While organizational vulnerabilities and attacker behavior have been studied extensively, it remains unclear what vulnerabilities were present in victim organizations' Internet-facing assets before the attack, and whether these differ from non-victims with similar attributes. This study investigates vulnerabilities in the public-facing assets of ransomware-victimized organizations at the time of attack, examining whether observed trends are specific to victims through a case-control comparison with a matched control group. We construct a pipeline reconstructing public-facing assets and vulnerabilities at the time of attack using Censys, DNSDB, and Shodan, integrated with NVD, CISA KEV, and FIRST EPSS, applied to ransomware.live victim data and a matched control group. We examine whether systematic differences exist across multiple indicators, and verify through robustness checks whether observed differences are artifacts of specific vulnerabilities or population subsets. We find no such differences except in known-ransomware-exploited vulnerability possession, where a borderline significant difference was observed, attributable to a single known vulnerability.

Keywords: Ransomware, Case-Control Study, Attack Surface, KEV/EPSS

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

インターネットに公開されたサーバ・ネットワーク機器等の資産（Attack Surface）に存在する既知脆弱性は，攻撃者にとって組織への初期侵入を実現する手段の一つである．攻撃者は脆弱性公表後数時間以内に大規模スキャンで脆弱なホストを発見し，発見されたホストはその後実際に攻撃を受ける割合が高い [1], [2]．ランサムウェア攻撃においても，Sophos による 17 か国 2,158 組織を対象とした 2026 年の調査で，既知脆弱性の悪用は認証情報の窃取に次ぐ侵入経路であったが，これを起点とする攻撃は身代金要求額が 100 万ドルを超える割合が全体平均の 48%を上回る 59%に達すると報告されており [3]，発生頻度以上に被害の深刻さと結びつく要因であることがうかがえる．こうした背景から，公開資産上の脆弱性とランサムウェア被害の関係を定量的に明らかにすることは，攻撃対象領域管理（Attack Surface Management）や脆弱性対応の優先順位付けの高度化に資する課題である．

これまでに，ランサムウェア被害組織の脆弱性に着目した研究は存在するものの，被害当時の技術的な公開資産の状況を，属性の類似した非被害組織と比較した研究は限られている．

そこで本研究では，この課題を解決するため，以下の 2 つのリサーチクエスチョン（RQ）を設定した．

RQ1：ランサムウェア被害組織の外部公開資産には，どのような既知脆弱性やサービスが露出しているか．

RQ2：ランサムウェア被害組織の外部公開資産における脆弱性の傾向は，属性の類似した非被害組織と比較して系統的な差があるか，またその差はどのような要因に起因するか．

ここで系統的な差とは，単一の母集団定義・対照比率における統計的有意差にとどまらず，複数の母集団定義および対照比率にわたって一貫して観測され，かつ特定少数の脆弱性や母集団の一部への依存に還元されない差を指す．RQ1 に対しては，ランサムウェアグループが運営するリークサイトを収集・公開しているデータセットである ransomware.live[4] に掲載された組織のうち，ドメインおよび IP 資産，すなわちインターネットに公開され外部から到達可能な IP アドレスとポートの組み合わせを特定できた 920 組織を対象とする．本研究では，インターネットに公開され外部から到達可能な IP アドレスを資産と呼ぶ．各資産は，複数のポート・サービスが稼働する 1 つの単位として扱う．各組織について，被害掲載日の 30 日前を基準時点とし，その時点で公開資産上に存在した既知脆弱性を Shodan[5] の観測履歴から再構成する．RQ2 に対しては，これらの被害組織を症例群とし，企業データベース Apollo.io[6] を用いて属性の類似した非被害組織を対照群として抽出する症例対照デザインを採用する．その上で，理論上の深刻度である CVSS に加え，実際の悪用実績を示す CISA KEV[7] と悪用確率の予測値である FIRST EPSS[8] を組み合わせ，症例群と対照群の脆弱性プロファイルを比較する．分析の結果，脆弱性検出率・CVSS による深刻度・EPSS による悪用予測スコアについては，症例群と対照群の間に系統的な差は見られなかった．ランサムウェアでの悪用実績が既知の脆弱性の保有率についてのみ境界的な有意差が観測されたが，この差は単一の既知脆弱性に起因するものであり，複数の母集団定義・対照比率による頑健性検証によってもこの構造は変わらなかった．

本研究の貢献は下記の通りである：

- ランサムウェア被害組織の被害当時の公開資産における既知脆弱性の傾向を，Shodan・NVD[9]・KEV・EPSS を組み合わせて再構成し，属性を一致させた対照群との症例対照比較により定量的に検証する，管見の限り初めての体系的分析を行った
- CVE 検出率・CVSS・EPSS 等の複数指標に広範な系統的差異が見られないことを，複数の母集団定義・マッチング比率にわたる頑健性検証によって示した，その差が単一の既知脆弱性に起因する見かけ上のものであることを明らかにし，外部スキャン指標のみでの判別の限界を指摘した

2. 関連研究

ランサムウェア被害組織を対象とした先行研究として，Connolly ら [10] は英国・北米の 55 事例を対象に被害の深刻度に影響する組織的要因を分析しているが，被害当時の技術的な公開資産・脆弱性の状況までは扱っていない．また，Allodi らは，症例対照デザインを応用し CVSS スコアが実際の悪用をどの程度予測できるかを脆弱性単位で検証しているが [11]，組織単位の比較やランサムウェア被害という文脈での検証は行っていない．また，Black Kite は被害組織の公開資産を掲載前後で再スキャンし，一定割合が重大な脆弱性を継続保有していることを報告しているが [12]，被害公表後の観測に基づく実務報告であり，属性を揃えた非被害組織との体系的な比較は行っていない．本研究は，被害組織の既知脆弱性（CVE/CVSS）に実際の悪用実績（KEV）・悪用確率予測（EPSS）を統合して攻撃発

[1] 横浜国立大学
Yokohama National University
[2] 横浜国立大学大学院環境情報学府
Graduate School of Environment and Information Sciences, Yokohama National University
[3] 横浜国立大学大学院先端科学高等研究院
Institute of Advanced Sciences, Yokohama National University
[4] 横浜国立大学大学院環境情報研究院/先端科学高等研究院
Faculty of Environment and Information Sciences, Yokohama National University / Institute of Advanced Sciences, Yokohama National University
[a)] mitsui-ai-rx@ynu.jp

© 2026 Information Processing Society of Japan

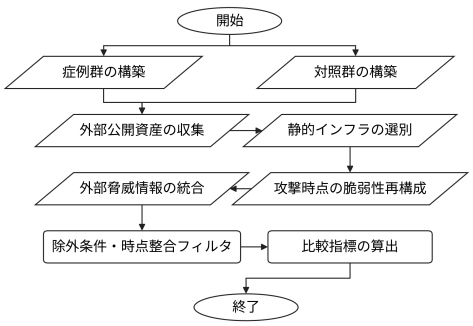


図 1 調査手法フローチャート

生時点の状態を Shodan の観測履歴から再構成し，属性の類似した非被害組織を対照群とする症例対照デザインを組織単位でランサムウェア被害という文脈に適用する点で，既存研究と差別化される．

3. 調査手法

図 1 に本研究の調査手法の全体像を示す．本研究では，被害組織である症例群と非被害組織である対照群をそれぞれ独立に構築した後，両群に対して同一の測定パイプラインを適用する．以下，各工程の詳細を順に述べる．

3.1 データセット

本研究の被害組織リストは，ランサムウェアグループのリークサイト掲載情報を収集した公開データセットである ransomware.live[4] に基づく．なお，身代金の支払い等で掲載を免れた被害組織は含まれないため，本研究が対象とするのはリークサイトに掲載された被害組織であり，被害組織全体を代表するものではない．ransomware.live 自身が把握する Web ドメインが空でなく，掲載日が対象期間内かつ正規のドメイン形式である記録を対象に，第三者サイトの誤登録・伏字化・公的接尾辞のみの記録を除外し，同一ドメインの重複は最も古い掲載日に統合した．この結果，掲載レコード 30,102 件のうち 1,173 件が有効なドメインを持つ組織として抽出され，さらにそのドメインから外部公開資産を確認できた 920 組織を母集団とした．2026 年 5 月 24 日〜7 月 23 日にリークサイトへの掲載が確認されたものを対象とする．

3.2 統制群の構築

対照群の候補は，企業情報データベースである Apollo.io[6] を用い，症例群 1 組織あたり主候補 2 件・予備候補 3 件の計 5 件を抽出した．該当するセル内の候補企業が 5 件に満たない場合は，得られた件数のみを候補とする．候補の抽出手順は以下の通りである．従業員規模帯・地域・業種が被害組織と完全に一致するセル内から候補企業を抽出し，売上規模および設立年の近さ順に上位 2 件を主候補，続く 3 件を予備候補とする．5 件に満たない場合は得られた件数のみとする．ransomware.live の掲載記録と照合し掲載歴のある企業を除外した上で，マッチング元の被害組織の掲載日を基準時点として引き継ぎ，同一の観測窓・手順・指標で資産と脆弱性情報を測定する．候補の採否は観測データの取得可否のみで判定し，CVE 検出の有無では判定しない．これにより，分析指標に基づく対照選抜バイアスを避けている．

3.3 外部公開資産の収集

被害組織・対照群の双方について，Censys[13] の Search API を用い，各組織の正規化済みドメイン名を検索条件として IP アドレスおよび関連するドメイン名を収集した．Censys は，インターネット全域スキャンにより観測した各ホストの情報を，ホスト名・IP アドレス・DNS レコード・証明書情報などの項目（以下，フィールド）に構造化して提供している．検索クエリには，組織ドメインとの関連性を高い精度で判定できるフィールドとして，`web.hostname`，`web.endpoints.hostname`，`web.endpoints.http.uri`，`web.endpoints.http.redirect_chain.hostname`，`host.dns.names`，`host.dns.forward_dns.value.name`，`host.dns.reverse_dns.names` の 7 フィールドを OR 条件として選定した．一方，本文全文一致や第三者連絡先情報等，誤検知を招きやすいフィールドは採用しなかった．

3.4 静的インフラの識別

Censys で収集した資産のうち，攻撃発生前に IP アドレスが変化していない静的インフラのみを分析対象とする．DNSDB[14] が提供するパッシブ DNS 情報を用い，関連ドメインが特定できた資産は正引き，できなかった資産は逆引きのパッシブ DNS 記録を取得する．症例群のリークサイト掲載日時から遡った 365 日間を判定窓とし，窓内で IP アドレスまたは関連ドメイン名の切り替わりが 0 回の資産のみ静的インフラとして採用し，1 回以上の変化がある資産，および窓内に記録が存在しない資産は除外する．

3.5 攻撃時点の脆弱性再構成

静的インフラとして識別された資産について，Shodan が保持するヒストリカルなバナー観測データを用い，攻撃発生当時の既知脆弱性（CVE）および CVSS スコアを再構成する．基準時点は，リークサイトへの掲載日の 30 日前とする．これは，掲載後に観測された姿を用いると，対応後・攻撃後の状態を測ることになってしまうためである．30 日という期間は，侵入から検出・暗号化に至るまでの期間 [15] と，暗号化後の交渉期間を経てリークサイトへ掲載されるまでの期間 [16] を合算し，侵入発生から掲載までがおよそ 1 か月前後に及ぶことを見込んで採用した．具体的には，資産が持つポートごとに，基準時点に最も近い日付のバナー観測を採用する．基準時点との前後関係は問わ

© 2026 Information Processing Society of Japan

ず，距離が最小となる観測のみを選択する．ただし，基準時点から 50 日を超えて離れた観測は，過大な帰属を避けるため採用しない．該当ポートの観測が存在しない資産，全ポートの観測が上記の窓を超えて除外された資産については，データなしとして扱う．

3.6 外部脅威情報の統合

再構成した CVE 情報に対し，以下の 3 つの外部脅威情報源を統合する．ここで CVE（Common Vulnerabilities and Exposures）は個々の脆弱性に付与される識別子，CVSS（Common Vulnerability Scoring System）は脆弱性の深刻度を 0 から 10 のスコアで表す指標，CWE（Common Weakness Enumeration）は脆弱性の型（入力検証の不備，認証の不備など）を分類する体系である．

- **NVD**：CVE ごとの CVSS スコア，CWE 分類，および公開日を取得する．CVSS はバージョン（v2.0，v3.0，v3.1）ごとに個別のフィールドとして保持し，バージョンをまたいだ平均・換算は行わない．深刻度区分（Critical/High/Medium/Low）は v3 系のみに付与し，Critical 区分の存在しない v2.0 には付与しない．
- **CISA KEV**：実際に悪用が確認された脆弱性のカタログであり，ランサムウェアでの悪用が既知か不明かを区別して記録する．
- **FIRST EPSS**：今後 30 日以内に悪用される確率の予測値であり，基準時点におけるリスク認識を反映するため，基準時点付近の日別スコアを個別に取得する．

3.7 除外条件・時点整合フィルタ

主要な比較の対象からは，以下の条件に該当する資産・組織を除外する．なお，アンブレラ組織の除外は症例群のみに適用する．対照群は ransomware.live への掲載記録を持たないため，複数の下部組織が重複して掲載されるというアンブレラ現象がそもそも生じえず，レビュー対象とならないためである．

- **アンブレラ組織の除外**：単一のドメインが複数の下部組織・無関係な組織の資産を含む場合，1 組織の資産規模が集計結果全体を支配しうる．症例群 325 組織の分析では，アンブレラ除外による資産行の減少の大部分が，多数のサブドメイン・IP アドレスを抱える大規模な政府ドメインわずか 3 組織に集中していた．外部公開資産数 36 件以上，または CVE 検出件数の寄与率 1%超の症例群組織を候補として抽出し，人手でレビューした上で除外の要否を判定する．
- **多テナント資産・CDN 資産**：共有ホスティング上の資産には，対象組織と無関係な第三者の資産が多数同居しており，検出される脆弱性が対象組織自身の管理下にあるとは限らない．この判定にはホスト名件数・ASN 所有者名・回線事業者名といった資産メタデータが必要であるが，対照群のデータにはこれらの列が存在しないため，判定自体を行うことができない．片群のみに判定・除外を適用すると，データのある適格資産の分母の定義が両群で非対称になり，症例対照比較の前提が崩れる．そこで本研究では，両群とも多テナント資産・CDN 資産を除外せず保持する方針を採用した
- **時点整合フィルタ**：CVE の公開日が基準時点より後の場合，攻撃発生時点では未知の脆弱性であることを意味し，フラグとして記録した上で主要分析からは除く．症例群 325 組織の CVE 行では，資産適格性フィルタ適用後の 13,219 行のうち 214 行が除外され 13,005 行となった．

3.8 比較指標の定義

組織単位の比較においては，資産規模の異なる組織を同じ基準で比較するため，組織あたり CVE 数のような資産数に依存する指標ではなく，既知脆弱性が検出された資産の割合を主要な指標として用いる．

主要分析では，症例群と対照群との間で，以下の複数の指標について差を検証する．

- CVE 検出率：既知脆弱性が 1 件以上検出された資産の割合
- CVSS による深刻度：v3 系の Critical または High 区分に該当する脆弱性の保有
- EPSS による悪用予測スコア：0.5 以上の脆弱性の保有
- KEV 収載状況：実際の悪用実績の有無，およびランサムウェアでの悪用実績が既知であるかの有無

比較に用いる統計手法は，指標の性質に応じて使い分ける．資産あたりの検出率のように組織ごとに算出した比率の平均を比較する連続変数には，Welch[17] 法を用いる．これは，等分散を仮定しない 2 群の平均差について，正規近似により信頼区間を求める手法である．一方，CVE 検出率・CVSS による深刻度・EPSS による悪用予測スコア・KEV 収載状況のように，組織単位での該当・非該当という二値の割合を比較する指標には，Newcombe[18] 法を用いる．これは，2 つの独立な Wilson 区間を合成することで，比率差の信頼区間を求める手法である．また，Newcombe 法で有意な差が観測された指標については，マッチング構造を反映した Mantel-Haenszel[19] オッズ比による頑健性確認をあわせて行う．母集団の定義を複数通り設定することで，特定の定義に依存しない結果か確認する．ここで，組織のドメインから Censys により資産が 1 件以上特定できた状態を資産解決済みと呼ぶ．具体的には，マッチングと露出観測の両方が揃った組織のみを対象とする定義，資産解決済みの全組織を対象としマッチング対象外の組織や露出ゼロの組織も含める定義，およびこれらに追加マッチングを施して完成させた定義の 3 通りを用いる．さらに，

© 2026 Information Processing Society of Japan

主要分析で有意な差が観測された指標については，その差が特定の脆弱性 1 件に依存する見かけ上のものでないかを，該当脆弱性を除いた場合の差の変化，母集団の部分集合ごとの層別分析，および対照比率，すなわち症例 1 件あたりの対照数を 1:1 から 1:5 まで変化させた場合の結果の安定性により検証する．

4. 調査結果

本章は，3 章で述べた 3.1 節から 3.8 節までの各手法に対応する形で構成する．3.1 節および 3.2 節の結果は 4.1 節で示す．3.3 節および 3.4 節の結果は，4.1 節の DNSDB 静的インフラ判定の内訳，および除外過程の内訳（表 1，表 2）で示す．3.5 節および 3.6 節の結果は，4.1 節の no_data 除外の内訳，および 4.2 節で示す．3.7 節の結果は，4.1 節の除外ファネル（表 3，表 4）で示す．3.8 節の結果は 4.3 節の各表で示す．

4.1 母集団・統制群の概要

リークサイトへの掲載レコード 30,102 件のうち，ドメインが特定できた組織は 1,173 件，外部公開資産を確認できた組織は 920 件，業種・従業員規模・売上・設立年が判明した組織は 325 件であった．3.8 節で述べた通り，この 325 件を起点に 3 通りの母集団定義を設定し，Shodan で資産の露出を実際に観測できた 226 件を主要分析の母集団と位置づける．残る 2 通りは露出ゼロの組織も含め，偏りを確認する．

比較に用いる母集団は，以下の 3 通りを設定した．

①：226 vs 430．症例群 226 組織に候補 5 件を基本として抽出し（一部は 5 件未満），合計 1,128 件を Shodan 観測に引き渡した．基準時点から前後 50 日の窓を適用し掲載後バナーを除外した条件でデータが取得できた候補は 755 件であり，各症例組織で近さ順に最大 2 件採用した結果，207 組織が対照 2 件，16 組織が対照 1 件，3 組織が対照 0 件となり，採用対照数は $207 \times 2 + 16 \times 1 = 430$ 件であった．

- 資産解決済み・マッチなしの母集団②：325 vs 373．共変量が完備している条件のみで症例群を 325 組織に拡張し，対照は同じ候補プールから主候補の先頭 2 件をそのまま採用し Censys で資産解決できた 373 件である．マッチング構造を用いず群単位でプールする探索的比較であるため，母集団①のような繰り上げ規則は適用していない．
- 資産解決済み・マッチありの母集団③：325 vs 646．母集団②の 325 組織のうち，母集団①で既にマッチング済みの 226 組織を除いた未マッチの 99 組織に対し，追加の対照マッチングを実行した．この追加マッチングでは，母集団①のマッチングと同一の割当規則・同一の距離尺度を用いる．距離尺度は母集団①のマッチング時点で固定した標準化尺度をそのまま使用し，既に対照として採用済みの企業を再度候補に含めない非復元の原則も引き続き適用する．母集団①で用いた候補 1,128 件と，今回の追加マッチングで得られた候補 495 件（未マッチ 99 組織に対して 1 組織あたり 5 件）を合わせた候補 1,623 件のうち，Censys で資産が解決できたのは 1,313 件であった．母集団①と同じ繰り上げ規則を 325 組織全体に適用した結果，321 組織が対照 2 件，4 組織が対照 1 件を確保し，採用された対照数の合計は $321 \times 2 + 4 \times 1 = 646$ 件であった．

表 1 対照候補プールの絞り込み過程（母集団①・③）

母集団	①	③
1. 割当候補	1,128 件	1,623 件
2. Censys/DNSDB 判定通過	922 / 7,763	1,313 / 9,819
3. no_data 除外後	904 / 6,719	1,289 / 8,602
4. 窓外除外後	819 / 5,785	1,140 / 7,319
5. バナー除外後	755 / 4,667	1,058 / 6,042

母集団③の候補プールである 1,623 件は，母集団①の候補 1,128 件に，未マッチ 99 組織への追加マッチングで得られた 495 件を加えたものである．各セルは「組織数 / 資産行数」を示す．

母集団①のみでは，外部に何も露出していない組織が集計から漏れる．こうした組織は，露出が小さいこと自体が対策の結果である可能性があるため，母集団②・③でこれを補っている．母集団①は，分析前に主要分析として定めたものであり，被害組織と対照組織の両方で外部公開資産を確認できた組織を対象とする．母集団②・③は，対象範囲やマッチング方法を変えても結果が変わらないかを確認するための補完的な分析である．

症例群 325 組織を対象に，Censys で収集された生候補 84,710 行に DNSDB のパッシブ DNS 判定を適用した結果，ドメイン側で 6,859 行・302 組織，IP 側で 4,082 行・223 組織が静的資産として生存し，統合・重複排除後は 325 組織全員が資産 1 件以上を保持し合計 5,935 行となった．

母集団①・③で用いられる対照候補プールの絞り込み過程を表 1 に示す．母集団①は候補 1,128 件を起点とする．母集団③は，この 1,128 件に加え，未マッチの 99 組織に対する追加マッチングで得られた 495 件を合わせた候補 1,623 件を起点とする．いずれも，Censys 解決・DNSDB 静的判定通過後の資産，Shodan でのデータ取得，観測窓の適用，掲載後バナー観測の除外という 4 段階を経て，最終的な候補プール（母集団①：755 組織，母集団③：1,058 組織）に絞り込まれる．この最終プールから，3.2 節で述べた繰り上げ規則により，母集団①は 430 件，母集団③は 646 件の対照が選定される．

一方，母集団②は，Censys・DNSDB 通過後の 922 組織から，マッチング順位の先頭 2 件を無条件に選定した 373 組織を対象とする．母集団①・③とは異なり，この 373 組織の選定自体は Shodan での観測データ取得の成否とは無

© 2026 Information Processing Society of Japan

表 2　母集団②における除外過程（選定後の事後計測）

段階	組織数	資産行数
0. 選定済み（373 組織）	373	2,876
1. no_data 除外後	369	2,440
2. 窓外除外後	333	2,159
3. 掲載後バナー除外後	300	1,587

表 3　症例群 325 組織における除外過程（資産単位）

段階	組織数	資産行数
0. 全資産行（325 組織）	325	5,935
1. データ無し除外後	294	4,669
2. 掲載後バナー除外後	284	4,269
3. アンブレラ除外後	281	2,287
4. CVE 検出資産を持つ組織	121	300

表 4　症例群 325 組織における除外過程（CVE 単位）

段階	組織数	CVE 行数
0. 全 CVE 行（325 組織中）	126	19,832
1. 資産適格性で内部結合後	121	13,219
2. 時点整合フィルタ除外後	121	13,005

関係に行われ，選定後に各種フィルタが指標計算のために事後的に適用される（表 2）．

症例群 325 組織を対象とした除外過程の内訳を表 3 に示す．全 5,935 資産行（325 組織）のうち，データが得られなかった資産の除外により 294 組織・4,669 行が残った．続いて，掲載後のバナー観測を除外した結果，284 組織・4,269 行が残った．アンブレラ組織の除外により，281 組織・2,287 行となった．最終的に，CVE 検出資産を持つ組織は 121 組織であった．CVE 単位での除外過程を表 4 に示す．CVE が 1 件以上検出された 126 組織・19,832 行を起点とし，資産適格性フィルタとの内部結合により 121 組織・13,219 行となった．続いて，時点整合フィルタにより，組織数に変化はなかったものの，214 行が除外され 13,005 行となった．

4.2　RQ1 の結果

以下の結果は，母集団②・③で共通して用いられる被害群 325 組織を対象とした集計である．本節の対象となった被害組織の外部公開資産における開放ポートの分布を図 2 に示す．80 番（HTTP）が 110 組織で最多，443 番（HTTPS）99 組織，22 番（SSH）48 組織と続き，これに次ぐポートはいずれも 5 組織以下にとどまり，露出面が Web 関連の少数のポートに集中していた．検出された脆弱性の CWE 分類別の該当組織数を図 3 に示す．CWE 分類が付与されていないとは，CVE 番号は特定できているが NVD が型を対応付けていない状態であり，脆弱性自体が未知という意味ではない．分類情報が記録されていないケース（NVD-CWE-noinfo）が 167 組織と最多を占め，入力検証の不備（CWE-20，129 組織），認証の不備（CWE-287，

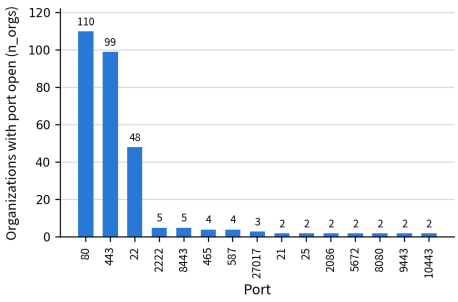


図 2　被害組織の外部公開資産にて観測された開放ポート

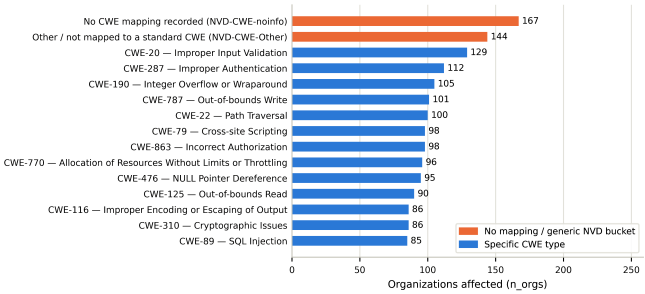


図 3　検出された脆弱性の CWE 分類別 該当組織数

112 組織）が続いた．CVSS の深刻度分布を v3 系に限定し，KEV 収載の有無別に見た結果を図 4 に示す（縦軸は各区分に該当する脆弱性を 1 件以上保有する組織の割合）．深刻度区分は CVSS v3.x の標準基準（Critical: 9.0 以上，High: 7.0 以上 9.0 未満，Medium: 4.0 以上 7.0 未満，Low: 0.1 以上 4.0 未満）に従った．いずれの区分でも KEV 非収載脆弱性を保有する組織の割合が収載脆弱性を上回り，特に Medium 区分では収載 9%に対し非収載 96%に達した．Low 区分では KEV 収載脆弱性を保有する組織は確認されなかった．なお，v3 系の指標が無く v2.0 のみの CVE は集計対象から除外している．この 325 組織を対象とした集計では，ユニーク CVE が合計 879 件検出された．このうち，CISA KEV に登録されていた CVE は 8 件（0.9%）であった．また，ランサムウェア攻撃での悪用が確認されている CVE は 4 件（0.5%）であった．一方，組織ごとに見ると，被害組織 325 組織のうち，ランサムウェア攻撃での悪用が確認されている CVE が少なくとも 1 件検出された組織は 28 組織（8.6%）であった．また，KEV に登録されている CVE，または EPSS スコアが 0.5 以上の CVE が少なくとも 1 件検出された組織は 108 組織（33.2%）であった．なお，1 つの製品から複数の CVE が一括検出される場合があり，これは独立した脆弱性の多さではなく Shodan が特定した製品バージョンの代理指標として解釈すべきである．

4.3　RQ2 の結果

組織内で脆弱性が検出された資産の割合について，3 通りの母集団いずれにおいても被害組織と対照群の間に統計的に有意な差は見られなかった（表 5）．母集団①では被害

© 2026 Information Processing Society of Japan

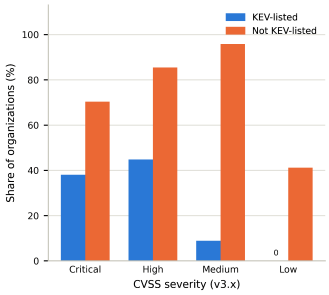


図 4 CVSS 深刻度区分別 KEV 収載有無による該当組織の割合

表 5 母集団別 脆弱性検出率の比較（Welch 法）

母集団	被害群	対照群	差	95%信頼区間	p 値
①	21.9%	25.4%	−3.5pt	[−9.1, +2.1]	0.217
②	17.6%	15.4%	+2.2pt	[−2.3, +6.6]	0.340
③	17.6%	17.0%	+0.6pt	[−3.5, +4.7]	0.775

p 値は，パイプラインが出力する差（diff）・標準誤差（se）から $z = diff/se$ として算出した．いずれの母集団も $p > 0.05$ であり，95%信頼区間が 0 をまたぐという判定と整合する．

組織の値が対照群をわずかに下回り，母集団②・③では逆に上回ったが，いずれも Welch 法による 95%信頼区間が 0 をまたいでおり，母集団定義の違いによる符号の反転にすぎない．CVE 検出率・CVSS による深刻度・EPSS による悪用予測スコアについても，母集団③における全指標を確認したところ，被害組織と対照群の間に有意な差は見られなかった（表 6）．

表 6 325 vs 646 の各指標比較（Newcombe 法）

指標	被害群	対照群	差 [95%CI]	p 値
CVE 検出率	37.2%	33.7%	+3.5 [−2.8, +9.9]	0.284
CVSS Critical	25.5%	24.0%	+1.5 [−4.1, +7.5]	0.599
CVSS High	30.8%	28.8%	+2.0 [−4.0, +8.2]	0.525
EPSS ≥0.5	32.3%	28.6%	+3.7 [−2.4, +9.9]	0.242

被害群 N=325，対照群 N=646．差の単位はポイント（pt）．4 指標いずれも $p > 0.05$ であり，95%信頼区間が 0 をまたぐという判定と整合する．

表 7 に，KEV 収載脆弱性保有率およびランサム悪用既知 KEV 保有率について，母集団③における被害群・対照群の比較を Newcombe 法で示す．KEV 収載脆弱性保有率には有意な差は見られなかった．ランサム悪用既知 KEV 保有率については 95%信頼区間の下限がわずかに 0 を上回り（$p \approx 0.053$），有意性の境界線上にあったため，マッチ構造を用いた Mantel-Haenszel 法による推定（OR 1.72, 95%CI [1.03, 2.87]）でも頑健性を確認した．

このランサム悪用既知 KEV 保有率の差について頑健性を検証したところ，老朽化した Apache httpd に関する特定の 1 件の既知脆弱性を除外すると差が消失し，他のいかなる CVE を除外しても差の大きさがほぼ変化しないことを確認した．また，被害組織を露出規模で層別すると，層によって差の符号が逆転することも確認された．さらに，

表 7 325 vs 646 における KEV 関連保有率指標の比較

指標	被害群	対照群	差 [95%CI]
KEV 収載脆弱性	19.1%	15.6%	+3.4 [−1.5, +8.7]
ランサム悪用既知 KEV	8.6%	5.1%	+3.5 [+0.2, +7.3]

被害群 N=325，対照群 N=646．差の単位はポイント（pt）．表の差・95%CI はいずれも Newcombe 法による．ランサム悪用既知 KEV 保有率のみ，境界的な有意差が観測されたため，マッチ構造を用いた Mantel-Haenszel 法によるオッズ比（OR 1.72，95%CI [1.03, 2.87]）を追加で算出した．

対照比率を 1:1 から 1:5 まで変化させても，組織内で脆弱性が検出された資産の割合はいずれの比においても有意差が見られなかった．KEV 収載脆弱性保有率の差は比率によって+2.5pt から+4.0pt の範囲で変動し，一部の比でのみ境界的に有意となる不安定なものであった一方，ランサム悪用既知 KEV 保有率の差は+3.3pt から+4.6pt の範囲で全ての比において観測されたが，いずれの比においてもその差は前述の単一の既知脆弱性 1 件に起因する構造であった．なお，外部への露出の有無という別の指標については，観測窓の設定，具体的には窓を揃えない場合，50 日の窓を揃えた場合，掲載後のバナーを除外した場合の 3 通りによって差の符号自体が反転することが確認された．両群の測定条件を完全に揃えた場合には，この指標にも有意差は見られなかった．

5. 考察

5.1 結果の考察

RQ2 の結果から，被害組織の外部公開資産における脆弱性の傾向は，属性の類似した非被害組織と比較して，広範な系統的差異を示すものではなかったと言える．CVE 検出率・CVSS による深刻度・EPSS による悪用予測スコアのいずれにおいても差が見られなかったことは，今回のデータでは，外部から観測可能な脆弱性指標に一貫した差を確認できなかったことを示している．本研究が測定したのは外部スキャンで観測可能な脆弱性であり組織の脆弱性管理体制そのものではなく，また有意差が確認されなかったことは両群が同等であることを証明するものではない．境界的な有意差が観測されたランサム悪用既知 KEV 保有率の差についても，その正体は体系的な脆弱性管理の差ではなく，特定の老朽化した製品 1 点の保有割合の違いに還元される．これは RQ1 で確認した「検出される CVE 件数は露出製品バージョンの代理指標である」という知見と同じ構造であり，個々の CVE の件数や有無を脆弱性の量として単純に解釈することの危険性を裏付けている．また，測定条件によって結論が変わりうることは，方法論上の教訓として重要であり，本研究が主要な比較指標・条件を分析実施前に確定し，結果を見た後に変更しなかったことの意義を裏付けている．以上を踏まえると，CVE・CVSS といった外部スキャンに基づく脆弱性指標のみでは，ランサ

© 2026 Information Processing Society of Japan

ムウェア被害組織と非被害組織を判別する材料として限界がある可能性が示唆される．本研究の結果は，外部から観測可能な既知脆弱性の分布という観点で両群に系統的な差が見出されなかったことを示すものであり，実際の初期侵入経路を特定するものではなく，この限界がどの程度侵入経路の違いに起因するのかは今後の課題である．

5.2 本研究の限界

本研究には，以下の限界がある．

- 対照群は身代金支払い等で掲載を免れた被害組織を含みうるため差が無いという結果は実際より小さく見積もられている可能性があり，また Shodan の 90 日の保有期間制約により，対象はリークサイト掲載から直近 60 日以内の事案に限られる．
- 95%信頼区間の幅から検出できるのは比較的大きな差に限られ，対象とする脆弱性も攻撃発生時点で該当しうるものであり実際に悪用された脆弱性を個別に特定したものではない．対照群の抽出は Apollo.io の収録範囲に依存する
- 対照群は症例群で用いた Shodan の生バナーキャッシュの取得工程を経ておらず，多テナント資産・CDN 資産の判定に必要な資産メタデータが存在しないため，両群とも除外せず保持する方針を採用した．

6. まとめと今後の課題

本研究では，ランサムウェア被害組織を症例，属性の類似した非被害組織を対照とする症例対照デザインにより，攻撃発生時点と考えられる時点の状態を再構成したの外部公開資産における既知脆弱性の傾向を検証した．RQ1 では，脆弱性は Web に関連する少数のポートに集中し，検出 CVE 件数は脆弱性の量というより露出製品バージョンの代理指標である場合があることを確認した．RQ2 については，複数の母集団定義・対照比率にわたり，CVE 検出率・CVSS による深刻度・EPSS による悪用予測スコアに被害組織と対照群の間の系統的な差は見られず，境界的な有意差が観測されたランサム悪用既知 KEV 保有率の差も，単一の既知脆弱性の保有割合の違いに起因する頑健性のないものであることを明らかにした．これらの結果は，今回のデータでは外部から観測可能な脆弱性指標に被害組織と非被害組織の間で一貫した差を確認できなかったことを示しており，外部スキャンに基づく CVE/CVSS ベースの評価だけでは，ランサムウェア被害リスクの判別材料として限界がある可能性を示している．今後の課題としては，対照群の定義の精緻化，外部スキャンに映らない侵入経路に関する指標との組み合わせ，母集団構築過程で失われた中間データの復元・再現性の確保が挙げられる．

謝辞 本研究の一部は，ＮＥＤＯ（国立研究開発法人新エネルギー・産業技術総合開発機構）の委託事業「経済安全保障重要技術育成プログラム／先進的サイバー防御機能・分析能力強化」（JPNP24003）によるものである．

参考文献

[1] Zakir Durumeric, et al. An Internet-Wide view of Internet-Wide scanning. In 23rd USENIX Security Symposium (USENIX Security 14), pp. 65–78, San Diego, CA, August 2014. USENIX Association.

[2] Elias Raftopoulos, et al. How dangerous is internet scanning? In Moritz Steiner, Pere Barlet-Ros, and Olivier Bonaventure, editors, Traffic Monitoring and Analysis, pp. 158–172, Cham, 2015. Springer International Publishing.

[3] SOPHOS. The state of ransomware 2025. Technical report, SOPHOS, 2025. Findings from an independent survey of 3,400 IT and cybersecurity leaders across 17 countries whose organizations were hit by ransomware in the last year.

[4] Julien Mousqueton. Ransomware.live. https://www.ransomware.live/, 2026.

[5] John Matherly. Shodan. https://www.shodan.io/, 2026.

[6] Apollo.io. Apollo.io. https://www.apollo.io/, 2026.

[7] Cybersecurity and Infrastructure Security Agency. Known exploited vulnerabilities catalog. https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2026.

[8] FIRST. Exploit prediction scoring system (epss). https://www.first.org/epss/, 2026.

[9] National Institute of Standards and Technology. National vulnerability database. https://nvd.nist.gov/, 2026.

[10] Lena Yuryna Connolly, et al. An empirical study of ransomware attacks on organizations: an assessment of severity and salient factors affecting vulnerability. Journal of Cybersecurity, Vol. 6, No. 1, p. tyaa023, 01 2020.

[11] Luca Allodi, et al. Comparing vulnerability severity and exploits using case-control studies. ACM Trans. Inf. Syst. Secur., Vol. 17, No. 1, August 2014.

[12] Black Kite Research Group. 2026 ransomware report: 7,551 victims, up 24.9%. https://blackkite.com/reports/2026-ransomware-report, 2026.

[13] Censys, Inc. Censys. https://censys.com/, 2026.

[14] DomainTools, LLC. Farsight dnsdb. https://www.domaintools.com/products/farsight-dnsdb/, 2026.

[15] Mandiant. M-trends 2026. https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026/, 2026.

[16] 関根悠司ら. Lockbit3.0 ウェブサイトのデータ変遷に基づく攻撃者と被害者の行動の分析. 信学技報, 電子情報通信学会 (IEICE), 2024. ICSS 研究会技術報告.

[17] B. L. Welch. The generalization of Student's problem when several different population variances are involved. Biometrika, Vol. 34, No. 1-2, pp. 28–35, 1947.

[18] Robert G. Newcombe. Interval estimation for the difference between independent proportions: Comparison of eleven methods. Statistics in Medicine, Vol. 17, No. 8, pp. 873–890, 1998.

[19] Nathan Mantel, et al. Statistical aspects of the analysis of data from retrospective studies of disease. Journal of the National Cancer Institute, Vol. 22, No. 4, pp. 719–748, 1959.

© 2026 Information Processing Society of Japan

研究倫理

本研究は，実在するランサムウェア被害組織および非被害組織の外部公開資産・脆弱性情報を扱っている．分析結果の公表にあたっては，個別組織を特定できる形での脆弱性の詳細，すなわち悪用に利用可能な水準の技術的情報を開示しないこととし，責任ある開示の原則に従う．また，非被害組織の抽出に用いた Apollo.io については，各社が定める利用規約の範囲内でデータを利用している．本研究が扱う脆弱性情報は，NVD・CISA KEV・FIRST EPSS・Censys・Shodan という，いずれも一般に公開されている情報源に基づくものであり，非公開の情報や不正アクセスによって得られた情報は用いていない．

© 2026 Information Processing Society of Japan